Gerenciamento de Incidentes de Segurança da Informação

Este documento contém informações confidenciais e pertence à SMILES S.A.

1 ENVOLVIDOS E VERSÕES DE DOCUMENTO 3
2 GERENCIAMENTO DE INCIDENTES DE SEGURANÇA DA INFORMAÇÃO 4
2.1 OBJETIVO 4
2.2 ESCOPO 4
2.3 CONCEITOS E DEFINIÇÕES 4
2.4 DIRETRIZES 9
2.5 INTERFACE COM OUTROS PROCESSOS 10
3 FLUXO MACRO "GERENCIAMENTO DE INCIDENTES DE SEGURANÇA DA INFORMAÇÃO" 11
3.1 DESCRIÇÃO DO FLUXO MACRO "GERENCIAMENTO DE INCIDENTES DE SEGURANÇA DA INFORMAÇÃO" 11
4 FLUXO DETALHADO "GERENCIAMENTO DE INCIDENTES DE SEGURANÇA DA INFORMAÇÃO" 12
4.1 DESCRIÇÃO DO FLUXO DETALHADO "GERENCIAMENTO DE INCIDENTES DE SEGURANÇA DA INFORMAÇÃO" 12
5 MATRIZ RACI 16
6 TABELA DE IMPACTO 17
6.1 NÍVEL DE IMPACTO 17
7 TABELA DE CATEGORIA 17
7.1 TABELA DE CATEGORIA X TIPO 18
8 TABELA DE PRIORIDADE (IMPACTO VS. URGÊNCIA) 18
9 TABELA DE FECHAMENTO 19
10 INDICADORES 19
11 DOCUMENTOS DE APOIO 19

Este documento contém informações confidenciais e pertence à SMILES S.A.

1 Envolvidos e Versões de Documento

Envolvidos			
Nome Completo	**Área**	**Email**	**Telefone**
Tânia Ferro	Chacon Consultoria	tania@chacon-ilimitada.com	

Data	Versão	Motivo	Autor	Descrição da Alteração

Histórico de revisões

Revisão	Data	Páginas Alteradas	Descrição da Motivação

Registros							
Registro	**Identificação**	**Legibilidade**	**Armazenamento**	**Proteção**		**Tempo de Retenção**	**Descarte**
				Indexação	**Acesso**		
Processo de Gerenciamento de Incidentes de Segurança da Informação	N/A	Elaborada no MS Word e Bizagi	Armazenado na Ferramenta "Confluence"	-	Os Funcionários da Smiles possuem acesso ao "Confluence" E os Terceiros podem ter acesso desde que liberado pela área de S.I.	N/A	N/A

2 Gerenciamento de Incidentes de Segurança da Informação

2.1 Objetivo

Este processo tem como objetivo identificar, notificar, registar e analisar todos os Eventos de Segurança da Informação.

E também visa gerenciar de formar eficiente o tratamento dos Incidentes de Segurança da Informação, recomendações ou penalizações e fluxo de comunicação.

2.2 Escopo

O processo de Gerenciamento de Incidentes de Segurança da Informação tem como escopo:

- Analisar todos os Eventos de Segurança da Informação identificados, notificados e registrados pelos colaboradores da Smiles;

- Realizar o levantamento de evidências / log´s, investigação, diagnóstico e resolução dos Incidentes de Segurança da Informação com apoio das áreas (Recursos Humanos, Jurídico, Comunicação, Marketing, Tecnologia da Informação, dentre outras áreas);

- Realizar o escalonamento dos Incidentes de Segurança da Informação de alto impacto "*Blocker*" para a Smiles.

Vale ressaltar que o processo de Gerenciamento de Incidentes de Segurança da Informação se relaciona com as normas e diretrizes contidos na Política de Segurança da Informação.

2.3 Conceitos e definições

A seguir, estão os principais conceitos e definições do processo de Gerenciamento de Incidentes de Segurança da Informação:

- **Ativo:** todo e qualquer bem, tangível ou intangível, que possua valor e significância para os negócios da Smiles. Exemplos de Ativos tangíveis podem ser imóveis, máquinas, estoque, computadores, entre outros. Exemplos de Ativos intangíveis podem ser experiências e conhecimentos acumulados (know-how), informações e dados, entre outros.

- **Colaboradores:** todo e qualquer Representante, Funcionário, Estagiário e Menor Aprendiz da Smiles e de suas associadas, incluindo os Prestadores de Serviço e Terceiros**.**

- **Comitê de Segurança da Informação:** formalmente constituído por colaboradores CLT para participar do grupo pelo período de dois anos. A composição mínima deve incluir um colaborador de cada uma das áreas: Gerência de Segurança da Informação e CIO.

- **Computadores:** é uma máquina capaz de variados tipos de tratamento automático de informações ou processamento de dados. Um computador pode possuir inúmeros atributos, dentre eles armazenamento de dados, processamento de dados, cálculo em grande escala, desenho industrial, tratamento de imagens gráficas, realidade virtual, entretenimento e cultura.

- **Conta (*Login*):** código identificador único de cada Colaborador na Rede Corporativa e / ou nos Serviços de TI / Sistemas de Informação, utilizado no processo de autenticação.

- **Conta Administrativa:** contas com acessos privilegiados aos sistemas e equipamentos de TI da Smiles, restritas apenas às equipes responsáveis pela administração técnica destes ambientes computacionais para utilização instalações, configurações, atualizações em geral.

- **Conta de Serviço:** contas criadas e utilizadas com a exclusiva finalidade de prover acessos entre Sistemas de Informação e Serviços de TI integrados.

- **Criptografia:** conjunto de técnicas que permitem codificar as informações transmitidas e / ou armazenadas entre computadores, de forma a impedir que sejam lidas ou decodificadas por pessoas não autorizadas.

- **Custodiante:** quem guarda as informações da Smiles, bem como preserva sua integridade, confidencialidade, disponibilidade e recuperabilidade.

- **Divulgação (Divulgar):** significa transmitir Informações para destinatários específicos.

- **Dispositivos de TI:** equipamentos de computação homologados e disponibilizados pela Smiles para uso dos colaboradores em suas atividades profissionais, realizando atividades de processamento, armazenagem e transmissão de Informações Eletrônicas. Podem ser Computadores (Desktops), Notebooks, Telefones Móveis (Celulares), periféricos (Pen-drive, HD externo) e Dispositivos Móveis Inteligentes, etc.

- **Dispositivos Móveis Inteligentes:** dispositivos móveis, exceto notebooks, que possuem as funcionalidades de processamento, armazenamento e comunicação de dados, como por exemplo tablets e smartphones.

- **Funcionário:** Colaborador com vínculo empregatício direto com a Smiles e regido pela CLT (Consolidação das Leis do Trabalho) Brasileira.

- **Evento de Segurança da Informação:** são considerados qualquer Evento adverso ou violação desta Política de Segurança da Informação **sob suspeita**, e relacionado a desvios de confidencialidade, integridade ou disponibilidade das Informações da Smiles. Exemplos de situações a serem consideradas para notificar um Evento de Segurança da Informação, mas não limitam aos mesmos:

  - Controle de segurança ineficaz;
  - Violação da disponibilidade, confidencialidade e integridade da informação;
  - Erros humanos;
  - Não conformidade com políticas ou diretrizes;
  - Violações de procedimentos de segurança física;
  - Mudanças descontroladas de sistemas;
  - Mau funcionamento de software ou hardware;
  - Violação de acesso.

- **Incidente de Segurança da Informação**: são considerados qualquer Evento adverso ou violação desta Política de Segurança da Informação **confirmado** pela Gerência de Segurança da Informação, e relacionado a desvios de confidencialidade, integridade ou disponibilidade das Informações da Smiles. Exemplos de Incidentes de Segurança da Informação incluem, mas não limitam aos mesmos:

  - Evasão de informações confidenciais;
  - Ataques de engenharia social;
  - Uso abusivo ou indevido de redes sociais para difamação, calúnia, ameaças ou fraudes;
  - Ausência na utilização de crachá em local visível;
  - Não conformidade com políticas ou procedimentos de segurança;
  - Comprometimento ou ataques de negação de serviço a sistemas de informação;
  - Uso ou acesso não autorizado a sistemas de informação;
  - Uso de credenciais de acesso que não sejam de sua propriedade;
  - Contaminações por malwares;
  - Recebimento de spam através das caixas de e-mail corporativo;
  - Cópia ou distribuição não autorizada de material protegido por direitos autorais;
  - Utilização de Internet para fazer difamação, calúnia e ameaças;
  - Tentativas de ataques a outros computadores;
  - Instalação de sistemas não homologados;
  - Destruição ou modificações indevidas em informações, sem o conhecimento, instruções ou consentimento prévio do proprietário ou gestor do ativo de informação;
  - Alteração do ambiente de produção, sem autorização do processo de Gerenciamento de Mudanças;
  - Publicação em ambiente de produção sem aprovação do Comitê Consultivo de Mudanças (CAB) do processo de Gerenciamento de Mudanças;
  - Desativação ou remoção de sistemas, como por exemplo, programas antivírus, agente de inventário ou qualquer outro instalado de forma padrão pela área de Tecnologia da Informação, bem como alterar configurações gerenciais das estações de trabalho;
  - Quaisquer ações e / ou situações que possam expor a Smiles, parceiros e / ou clientes à perda financeira e de imagem, direta e / ou indiretamente, potenciais e / ou reais, comprometendo seus ativos da Informação;

- Utilizações indevidas de dados corporativos, divulgação não autorizada de informações, segredos comerciais ou outras informações sem a permissão expressa da Gerência de Segurança da Informação e / ou Diretoria de Gestão;
- O uso de dados, informações, equipamentos, software, sistemas, serviços e / ou outros recursos tecnológicos, para propósitos ilícitos, que possam incluir a violação de leis, de regulamentos internos e externos, da ética ou de exigências de órgãos reguladores da área de atuação da **Smiles**, parceiros e / ou clientes.

- **Informação (Ativo de Informação):** ativo intangível e muito importante que deve ser adequadamente protegido e que abrange todas as informações relacionadas aos negócios da **Smiles**, elaboradas ou obtidas no decorrer das operações de todas as suas Divisões, Áreas e Departamentos. As informações estão contidas em Documentos Impressos, Documentos manuscritos, Arquivos Eletrônicos armazenados em Dispositivos de TI ou Mídias Digitais (CDs, DVDs, pen-drives e afins), Serviços de TI, Sistemas de Informação, Arquivos de Áudio e/ou Vídeo e também em transmissões de dados eletrônicas ou verbais em decorrência de rotinas de trabalho, reuniões, conferências ou conversas, por qualquer colaborador dentro ou fora da **Smiles**.

- **Informação Confidencial:** significa qualquer informação que deva ser mantida em sigilo (segredo) com base em sua relevância, importância e confidencialidade para os negócios, e que poderia causar danos ou prejuízos à **Smiles**, caso divulgadas para qualquer outra pessoa que não as exclusivamente designadas pela **Smiles**. Informações Confidenciais incluirão as "Informações Estritamente Confidenciais", a menos que possam ser interpretadas e diferenciadas contextualmente.

- **Informação Estritamente Confidencial:** significa qualquer informação que deva ser mantida em sigilo absoluto (segredo) com base em sua extrema relevância, importância e confidencialidade para os negócios, o que poderia causar danos ou prejuízos muito graves para a **Smiles**, caso divulgadas para qualquer outra pessoa que não as exclusivamente designadas pela **Smiles**.

- **Informações de Uso Interno:** significa, em princípio, qualquer informação não confidencial que não deva ser divulgada a qualquer outra parte que não os próprios Colaboradores da **Smiles**.

- **Informação Eletrônica:** informação elaborada, transmitida, armazenada ou tratada utilizando algum Sistema de Informação ou Serviço de TI da **Smiles**.

- **Informações Pessoais e Informações de Colaboradores**: nome, endereço, data de nascimento ou qualquer outra informação referente à identificação de qualquer pessoa que mantenha relação direta ou indireta com a **Smiles** seja como Colaborador (Representante, Funcionário ou Estagiário), Cliente (Consumidor) ou Fornecedor (Prestador de Serviços).

- **Perfis de Acesso:** são agrupamentos de um determinado conjunto de permissões e restrições dentro de um sistema de informação. Cada usuário de um sistema deve possuir um ou mais perfis de acesso, de acordo com as necessidades específicas de sua função.

- **Proprietário da Informação:** Representante ou, por delegação formal do Representante, um funcionário de nível hierárquico gerencial mais elevado de determinada divisão ou departamento, que possa decidir sobre a melhor gestão ou tratamento das Informações pertinentes à sua divisão ou departamento, sempre de forma alinhada a esta Política de Segurança da Informação.

- **PSI:** Acrônimo de Política de Segurança da Informação.

- **Publicação (Publicar):** significa tornar as informações disponíveis para o acesso do público em geral.

- **RACI:** matriz RACI tem como objetivo definir papéis e responsabilidades.

- **Rastreabilidade:** capacidade de traçar o histórico ou simplesmente "seguir o rastro" de um determinado item através de seus dados de controle (dados rastreáveis). Em relação à Segurança da Informação, refere-se à capacidade de identificar "quem" executou ou transmitiu "o quê", "onde" e "quando", bem como a origem e o destino das informações.

- **Recursos de Autenticação:** mecanismos de tecnologia apropriados que possibilitam verificar e realizar a identificação positiva de cada usuário autorizado a acessar determinado Serviço de TI, Sistema de Informação ou Rede.

- **Rede:** conjunto de equipamentos de comunicação e computadores que possibilitam a transmissão eletrônica de informações.

- **Rede Corporativa Smiles:** significa a Rede própria da Smiles utilizada para interconectar seus Dispositivos de TI, Servidores de TI e Serviços de TI, além de ser utilizada para controlar o acesso não autorizado externo, tornando-se um meio disponível para a transmissão segura de Informações Eletrônicas utilizada pela Smiles.

- **Reset de Senha:** procedimento de redefinição da senha de uma ou mais contas.

- **RH:** Acrônimo de Recursos Humanos.

- **Segurança da Informação:** conjunto de controles de proteção, tecnológicos e/ou processuais, aplicados na preservação da confidencialidade, integridade e disponibilidade das informações da Smiles, de modo a evitar sua divulgação ou uso indevido e também para garantir a continuidade dos negócios.

- **Serviços de TI:** representa o conjunto de recursos computacionais (hardware, serviços de software e software) utilizados para processar, armazenar, transmitir Informações Eletrônicas, incluindo os Sistemas de Informação da Smiles, Serviços baseados em nuvem, Mídias Sociais, Aplicações Web, entre outros.

- **Servidor de TI:** representa os equipamentos utilizados para armazenar e processar, de forma centralizada, Informações Eletrônicas utilizadas para fins empresariais.

- **SI:** Acrônimo de Segurança da Informação.

- **Sistemas de Informação:** também conhecidos como aplicações, são o conjunto de recursos computacionais utilizados para realizar a coleta, armazenamento e a manipulação de dados e informações, com o objetivo de possibilitar a realização de inúmeras atividades empresariais, tais como planejamentos, controles, análises de problemas, entendimento de questões complexas e tomadas de decisão.

- **Visitado:** todo colaborador responsável por acompanhar, do início ao fim, a visita de qualquer pessoa sem vínculo contratual com a Smiles e que esteja visitando as dependências da Smiles.

- **Visitante:** toda e qualquer pessoa sem vínculo contratual com a Smiles, que possa visitar as dependências da Smiles, sempre sob a responsabilidade de um colaborador.

- **TI:** Acrônimo de Tecnologia da Informação.

- **Usuário (Usuário de TI):** todo Colaborador que possua Contas de acesso a Sistemas de Informação, Serviços de TI e/ou Dispositivos de TI disponibilizados para seu uso profissional.

2.4 Diretrizes

O processo de Gerenciamento de Incidentes de Segurança da Informação possui as seguintes diretrizes:

- **Ferramenta** – ferramenta oficial da Smiles para notificação e registro do Evento de Segurança da Informação e tratamento dos Incidentes de Segurança da Informação é o Jira.

- **Gerenciamento de Incidentes de Segurança da Informação -** Haverá apenas um processo de Gerenciamento de Incidentes de Segurança da Informação para toda organização, sob a responsabilidade da equipe de Segurança da Informação.

- **Acesso** - somente a Gerência de Segurança da Informação e o CIO devem ter acesso aos Eventos de Segurança da Informação, Incidentes de Segurança da Informação e o seu tratamento na ferramenta Jira.

- **Notificação e Registro do Evento de Segurança da Informação** - todos os colaboradores devem notificar e registrar imediatamente a Gerência de Segurança da Informação sobre possíveis Eventos de Segurança da Informação através ferramenta Jira. O nome do colaborador que registrar um Evento de Segurança da Informação, deve ser mantido em sigilo e / ou confidencial pela Gerência de Segurança da Informação. O colaborador não precisa seguir as regras de hierarquia para abrir um Evento de Segurança da Informação.

- **Recomendação ou penalização** – a Gerência de Segurança da Informação e o Comitê são responsáveis por emitir um relatório de parecer de recomendação ou penalização. A

aplicação ou não da recomendação ou penalização é de responsabilidade das outras áreas de apoio da Smiles.

- **Política de Segurança da Informação** - o processo de Gerenciamento de Incidentes de Segurança da Informação se relaciona com as normas e diretrizes contidos na Política de Segurança da Informação.

2.5 Interface com outros processos

O Gerenciamento de Incidentes de Segurança da Informação possui interfaces com outros processos de TI, como podem ser vistas nos tópicos abaixo:

Gerenciamento de Mudanças:

- Para resolver uma vulnerabilidade técnica descrita em um Incidente de Segurança da Informação pode ser necessária a abertura de uma *Request for Change* (CAB) que deverá ser aprovada pelo processo de Gerenciamento de Mudanças da Smiles;
- A execução de uma *Request for Change* (CAB) aprovada pode gerar Eventos de Segurança da Informação durante ou após a sua implantação. É de responsabilidade do processo de Gerenciamento de Mudanças realizar a notificação deste tipo de ocorrência, após a revisão-pós-implantação (RPI);
- É de responsabilidade do Analista de Segurança da Informação participar de todas as reuniões do Comitê Consultivo de Mudanças (CAB) e deliberar pelas *Request for Change* (CAB) avaliando se está aderente as normas e diretrizes de Segurança da Informação.

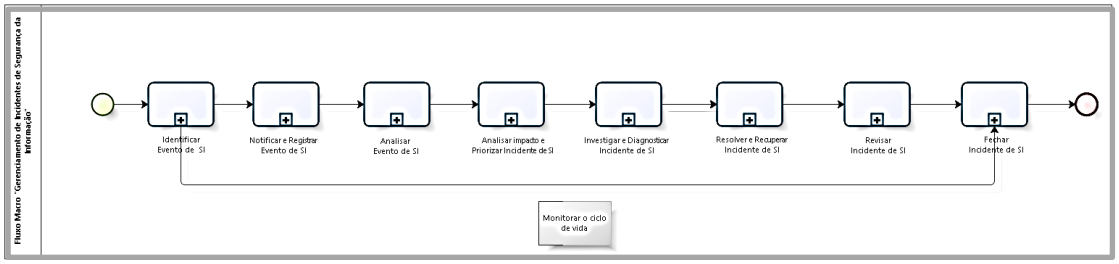
Gerenciamento de Incidentes de TI:

- Um Incidente de Segurança da Informação pode estar relacionado a um Incidente de TI (mau funcionamento ou comportamento anômalo em um serviço de TI), que possa indicar uma eventual violação e / ou ataque do ambiente. É de responsabilidade do processo de Gerenciamento de Incidentes de TI a notificação deste tipo de ocorrência.

Gerenciamento de Problemas:

- A investigação da causa raiz de um Registro de Problema pode indicar um Evento de Segurança da Informação (vulnerabilidade e / ou ameaças);
- Para resolver um alto índice de Incidentes de Segurança da Informação, pode utilizar as técnicas e / ou procedimentos do processo de Gerenciamento de Problemas.

3 Fluxo Macro "Gerenciamento de Incidentes de Segurança da Informação"



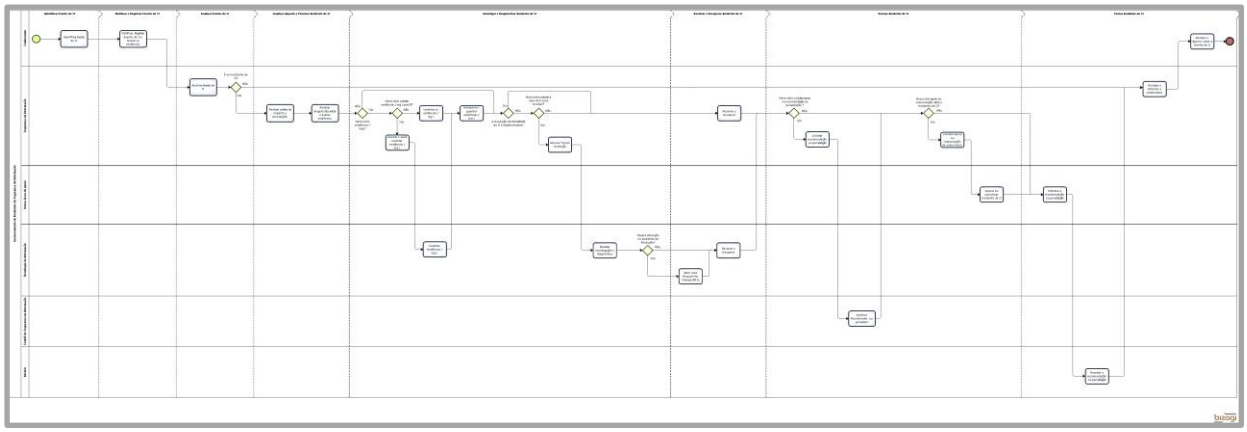
3.1 Descrição do Fluxo Macro "Gerenciamento de Incidentes de Segurança da Informação"

Atividade	Descrição
Identificar Evento de SI	A identificação de um Evento de Segurança da Informação pode ser realizada por qualquer colaborador da Smiles.
Notificar e Registrar Evento de SI	A notificação e o registro de um Evento de Segurança da Informação pode ser realizada por qualquer colaborador da Smiles.
Analisar Evento de SI	A Gerência de Segurança da Informação deve analisar todos os Eventos de Segurança da Informação registrados na ferramenta Jira. **Finalizar e informar o colaborador:** Caso o Evento de Segurança da Informação não seja um Incidente de Segurança da Informação, deve finalizar e informar ao colaborador que registrou. **Analisar impacto e Priorizar Incidente de SI:** Caso o Evento de Segurança da Informação seja um Incidente de Segurança da Informação, deve realizar a análise de impacto e priorizar.
Analisar impacto e Priorizar Incidente de SI	A Gerência de Segurança da Informação deve realizar a análise de impacto e priorizar do Incidente de Segurança da Informação.
Investigar e Diagnosticar Incidente de SI	A Gerência de Segurança da Informação deve realizar o diagnóstico inicial e avaliar as evidências em anexo na ferramenta Jira.
Resolver e Recuperar Incidente de SI	A Gerência de Segurança da Informação - Deve acionar a área de Tecnologia da Informação para solucionar, caso seja técnico através da abertura de um novo incidente de TI na ferramenta Jira. - Deve resolver e recuperar, caso seja administrativo ou não necessite de resolução da área de Tecnologia da Informação.
Revisar Incidente de SI	A Gerência de Segurança da Informação - Pode solicitar recomendação ou penalização ao Comitê de Segurança da Informação, caso julgue necessário.

Este documento contém informações confidenciais e pertence à SMILES S.A.

	- Pode solicitar apoio ou comunicação interna / externa de outras áreas da Smiles conforme necessidade.
Fechar Incidente de SI	A Gerência de Segurança da Informação deve finalizar o Incidente de Segurança da Informação na ferramenta Jira. A Gerência de Segurança da Informação deve informar o seu parecer contendo a recomendação ou penalização as outras áreas de apoio.
Monitorar o ciclo de vida	Realizar a monitoração do ciclo de vida de todos os Eventos de Segurança da Informação e Incidentes de Segurança da Informação, caso seja necessário.

4 Fluxo detalhado "Gerenciamento de Incidentes de Segurança da Informação"



4.1 Descrição do Fluxo detalhado "Gerenciamento de Incidentes de Segurança da Informação"

Atividade	Descrição
Colaborador	
Identificar Evento de SI	A identificação de um Evento de Segurança da Informação pode ser realizada por qualquer colaborador da Smiles.
Notificar, Registrar Evento de SI e anexar as evidências	A notificação e o registro de um Evento de Segurança da Informação pode ser realizada por qualquer colaborador da Smiles. Vale ressaltar: - O nome do colaborador que registrar um Evento de Segurança da Informação, deve ser mantido em sigilo e / ou confidencial pela Gerência de Segurança da Informação; - O colaborador não precisa seguir as regras de hierarquia para abrir um Evento de Segurança da Informação;

	- Todos os colaboradores devem notificar imediatamente a Gerência de Segurança da Informação sobre possíveis Eventos de Segurança da Informação através ferramenta Jira; - O registro de um Evento de Segurança da Informação deve conter o maior detalhamento possível para análise, diagnóstico e resolução da Gerência de Segurança da Informação, tais como: o Local onde o evento foi identificado; o Data e Hora; o Descrição detalhada do incidente ou suspeita; o Quaisquer informações que tenham sido utilizadas para identificação do evento.
Segurança da Informação	
Analisar Evento de SI	A Gerência de Segurança da Informação deve analisar todos os Eventos de Segurança da Informação registrados na ferramenta Jira. **Finalizar e informar o colaborador:** Caso o Evento de Segurança da Informação não seja um Incidente de Segurança da Informação, deve finalizar e pode informar ao colaborador que registrou. **Realizar análise de impacto e priorização:** Caso o Evento de Segurança da Informação seja um Incidente de Segurança da Informação, deve realizar a análise de impacto e priorizar.
Realizar análise de impacto e priorização	A Gerência de Segurança da Informação deve realizar a análise de impacto e priorizar do Incidente de Segurança da Informação. Vale ressaltar: - Impacto é definido conforme tabela deste documento. - Prioridade é efetuada automaticamente com base na categoria selecionada na ferramenta Jira.
Realizar diagnóstico inicial e avaliar evidências	A Gerência de Segurança da Informação deve realizar o diagnóstico inicial e avaliar as evidências em anexo na ferramenta Jira. Vale ressaltar, que deve analisar se haverá necessidade de outras evidências / log´s para realizar o tratamento do Incidente de Segurança da Informação.
Levantar as evidências / log´s	Caso sejam necessárias outras evidências / log´s e a Gerência de Segurança da Informação tenha permissão de acesso / skill, ela deve realizar este levantamento.
Acionar TI para levantar evidências / log´s	Caso sejam necessárias outras evidências / log´s e a Gerência de Segurança da Informação não tenha permissão de acesso / skill, ela deve acionar a área de Tecnologia da informação para realizar esta atividade através da abertura de uma nova solicitação na ferramenta Jira.
Tecnologia da Informação	
Levantar evidências / log´s	A área de Tecnologia da Informação deve levantar as evidências / log´s solicitados e encaminhar através da ferramenta Jira.
Segurança da Informação	
Armazenar / guardar evidências / log´s	A Gerência de Segurança da Informação deve armazenar / guardar as evidências / log´s referente ao Incidente de Segurança da Informação atendendo os requisitos de confidencialidade, integridade, disponibilidade e conformidade.

Este documento contém informações confidenciais e pertence à SMILES S.A.

	Vale ressaltar, que a Gerência de Segurança da Informação deve verificar se o Incidente de Segurança da Informação é Administrativo / Técnico.
Acionar TI para resolução	A Gerência de Segurança da Informação deve acionar a área de Tecnologia da Informação para resolver e recuperar, caso seja técnico através da abertura de um novo incidente de TI na ferramenta Jira.
Resolver e recuperar	A Gerência de Segurança da Informação deve resolver e recuperar, caso a resolução seja administrativo ou não necessite da área de Tecnologia da Informação.
Tecnologia da Informação	
Realizar investigação e diagnóstico	A área de Tecnologia da Informação Tecnologia da Informação deve realizar investigação e diagnóstico para resolver. **Abrir uma *Request for Change* (RFC):** Caso seja necessário alterar o ambiente de Produção para resolver o Incidente de Segurança da Informação a área de Tecnologia da Informação deve abrir uma *Request for Change* (RFC), e seguir o fluxo de aprovação do processo do Gerenciamento de Mudanças.
Abrir uma *Request for Change* (RFC)	A área de Tecnologia da Informação deve abrir uma *Request for Change* (RFC), e seguir o fluxo de aprovação do processo do Gerenciamento de Mudanças. Vale ressaltar, que somente após a aprovação formal do processo de Gerenciamento de Mudanças poderá dar prosseguimento ao atendimento da solução.
Resolver e recuperar	A área de Tecnologia da Informação deve resolver e recuperar o Incidente de Segurança da Informação e encaminhar através da ferramenta Jira.
Segurança da Informação	
Solicitar recomendação ou penalização	A Gerência de Segurança da Informação pode solicitar recomendação ou penalização ao Comitê conforme necessidade.
Solicitar apoio ou comunicação de outras áreas	A Gerência de Segurança da Informação pode solicitar apoio ou comunicação interna / externa de outras áreas da Smiles conforme necessidade.
Comitê de Segurança da Informação	
Analisar, Recomendar ou penalizar	O Comitê de Segurança da Informação deve realizar uma análise e informar qual é o parecer em relação ao Incidente de Segurança da Informação cometido. Vale ressaltar, que o Comitê de Segurança da Informação informa o parecer de uma recomendação ou penalização, porém cabe as outras áreas de apoio aplicar ou não.
Outras áreas de apoio	
Apoiar ou comunicar Incidente de SI	As outras áreas devem realizar um apoio ou comunicação interna / externa de conforme o Incidente de Segurança da Informação. Vale ressaltar, que as áreas de apoio podem ser: ○ Recursos Humanos; ○ Jurídico; ○ Marketing; ○ Relação com os investidores; ○ Comunicação; ○ Tecnologia da Informação e etc.
Informar a recomendação ou penalização	As outras áreas devem informar a recomendação ou penalização ao infrator, caso seja definido.

Infrator	
Receber a recomendação ou penalização	O infrator deve receber a recomendação ou penalização sobre o Incidente de Segurança da Informação que havia cometido.
Segurança da Informação	
Finalizar e informar o colaborador	A Gerência de Segurança da Informação deve finalizar o Incidente de Segurança da Informação. Vale ressaltar, que é opcional que a Gerência de Segurança da Informação informar o colaborador da finalização e o as ações que foram executadas.
Colaborador	
Receber o retorno sobre o Evento de SI	O colaborador pode receber o retorno sobre a finalização e as ações tomadas sobre o Evento de Segurança da Informação, caso seja definido pela Gerência de Segurança da Informação.

5 Matriz RACI

Atividades	CIO	Colaborador	SI	Outras áreas de apoio	Tecnologia da Informação	Comitê de Segurança da Informação	Infrator
Responsável pelo sucesso do processo	A	-	-	-	-	-	-
Identificar Evento de SI	-	R	I	-	-	-	-
Notificar, Registrar Evento de SI e anexar as evidências	-	R	I	-	-	-	-
Analisar Evento de SI	-	-	R	-	-	-	-
Realizar análise de impacto e priorização	-	-	R	-	-	-	-
Realizar diagnóstico inicial e avaliar evidências	-	-	R	-	-	-	-
Levantar as evidências / log´s	-	-	C, I, R	-	I, R	-	-
Acionar TI para levantar evidências / log´s	-	-	R	-	I	-	-
Armazenar / guardar evidências / log´s	-	-	R	-	-	-	-
Acionar TI para resolução	-	-	R	-	I	-	-
Abrir uma *Request for Change* (RFC)	-	-	C, I	-	R	-	-
Resolver e recuperar	-	-	C, I, R	-	R	-	-
Analisar, Recomendar ou penalizar	I	-	C, I, R	-	-	C, R	-
Apoiar ou comunicar Incidente de SI	-	-	C, I, R	R	-	-	-
Informar a recomendação ou penalização	-	-	C, I	R	-	-	I
Receber a recomendação ou penalização	-	-	C, I	-	-	-	R
Finalizar e informar o colaborador	-	-	R	-	-	-	-
Receber o retorno sobre o Evento de SI	-	R	C, I	-	-	-	-

Este documento contém informações confidenciais e pertence à SMILES S.A.

6 Tabela de Impacto

IMPACTO	DESCRIÇÃO
Degradação de Imagem	Anuncio ou divulgação na mídia sobre o Incidente de Segurança da Informação envolvendo a empresa, através de Sites, Redes Sociais, Blogs, Televisão, Rádio, e outros canais de comunicação.
Perda Financeira	Roubo, furto ou perda de produtos ou serviços com valor monetário.
Regulatório	Descumprimento de leis, normas, políticas públicas ou privadas.
Tecnológico	Indisponibilidade parcial ou total de recursos ou serviços tecnológicos de infraestrutura como aplicações, servidores, dispositivos móveis e fixos, redes de voz e dados.

6.1 Nível de Impacto

BAIXO	MÉDIO	ALTO
Grupo ou comunidade restrita em blogs, redes sociais e canais IRC. Sem exposição em mídia digital e/ou impressa.	*Grupo ou comunidade restrita em blogs, redes sociais e canais IRC. Com exposição em mídia regional digital e/ou impressa.*	*Exposição em mídia digital e/ou impressa, de alcance nacional ou internacional. Redes sociais e outros sites de Internet.*

7 Tabela de Categoria

CATEGORIA	DESCRIÇÃO
Ataque Externo	Fraude eletrônica com o intuito de adquirir informações sensíveis da companhia e/ou de usuários. O ataque externo também pode ser caracterizado por tentativas em tornar os recursos de um sistema, operações as redes ou aplicativos indisponíveis.
Mau Uso Acidental e/ou Deliberado	Comportamento imprudente (erro operacional ou fraude) dos usuários em relação aos sistemas, que podem ser fatores indutores de vulnerabilidade e brechas na segurança da informação.
Mau funcionamento de sistema	Fatores como interrupção na comunicação, falhas de software, hardware, antivírus, desastres naturais e ataques externos.
Mau Uso Interno e Abuso	Acesso não autorizado à informação, alteração ou modificação não autorizada de sistemas, aplicativos, dados, acesso físico aos ambientes sem expressa autorização, divulgação de informações confidenciais e/ou não cumprimento das diretrizes da Smiles.
Roubo/Furto	Subtração de equipamentos e vazamento de informações confidenciais.
Componente Múltiplo	Incidente de Segurança da Informação que se enquadra em mais de uma classificação.

7.1 Tabela de Categoria x Tipo

CATEGORIA	TIPO
Ataque Externo	• Engenharia social; • Negação de serviço (denial of service); • Pichação em website; • Malwares.
Mau Uso Acidental e/ou Deliberado	• Erro de equipe de sustentação; • Acionamento de alarmes de incêndio.
Mau Uso Interno e Abuso	• Acesso a sites não relacionados ao negócio; • Acesso indevido aos ativos de informação; • Alteração de privilégios de sistemas; • Alteração, remoção ou instalação de software; • Divulgação de informações a pessoas não autorizadas; • Divulgação de informações de autenticação (usuário/senha); • Download/Upload ou envio de conteúdo inapropriado; • Violação das políticas internas da Smiles; • Alteração do ambiente de produção, sem autorização do processo de Gerenciamento de Mudanças; • Publicação em ambiente de produção sem aprovação do Comitê Consultivo de Mudanças (CAB) do processo de Gerenciamento de Mudanças.
Roubo/Furto	• Equipamentos; • Informações; • Informações de autenticação (usuário/senha).
Componente Múltiplo	• Incidente de Segurança da Informação que se enquadra em mais de uma classificação.

8 Tabela de Prioridade (Impacto vs. Urgência)

Gerenciamento de Incidentes de Segurança da Informação

Definições de SLAs

Criticidade	Janela de Atendimento	Incidentes		Solicitações	
		Tempo de Resposta	Tempo de Solução	Tempo de Resposta	Tempo de Solução
BLOCKER	24x7	1:00:00	4:00:00	-	-
CRITICAL	8x5	4:00:00	8:00:00	2:00:00	4:00:00
MAJOR	8x5	8:00:00	24:00:00	8:00:00	24:00:00
MINOR	8x5	-	-	8:00:00	40:00:00
TRIVIAL	-	-	-	-	-

9 Tabela de Fechamento

Código de Fechamento	Definição
Não procede	Realizado análise da Gerência de Segurança da Informação, e foi detectado que não se trata de um Incidente de Segurança da Informação.
Penalização	Foi aplicado uma penalização ao infrator.
Recomendação	Foi aplicado uma recomendação ao infrator.
Sem ação	Não foi aplicado uma recomendação e / ou penalização ao infrator.

10 Indicadores

Para o processo de Gerenciamento de Incidentes de Segurança da Informação temos definidos alguns indicadores de desempenho dentro da ferramenta JIRA, sendo eles:

- Quantidade de Eventos de Segurança da Informação abertos vs. Quantidade de Incidentes de Segurança da Informação resolvidos;
- Idade média dos Incidentes de Segurança da Informação abertos (Dias);
- Tempo médio de resolução (Dias);
- Quantidade de Incidentes de Segurança da Informação por categoria;
- Quantidade de Incidentes de Segurança da Informação por categoria e tipo.

11 Documentos de apoio

- Política de Segurança da Informação;
- Guia rápido do processo - Gerenciamento de Incidentes de Segurança da Informação;
- Guia rápido da ferramenta - Gerenciamento de Incidentes de Segurança da Informação;
- Template - Relatório de Parecer de Gerenciamento de Incidentes de Segurança da Informação;
- Apresentação - Treinamento de Gerenciamento de Incidentes de Segurança da Informação.

Este documento contém informações confidenciais e pertence à SMILES S.A.